



API Security Risk Analysis Report

:- BY MEET KHAMAR (FIT/MAY26/CS8556)



Introduction

I performed a read-only API security assessment on a public demo API. The objective was to identify potential security risks in API design and explain their business impact in a clear, practical manner.

The below report contains the below categories for each risk identified.

- API tested
- Identified risks
- Risk severity (Low / Medium / High)
- Business impact
- Remediation suggestions

API tested

- <https://jsonplaceholder.typicode.com/posts/1/comments>

IDENTIFIED RISKS

Finding 1 — Public Data Access Without Authentication

Observation: The API is not secure and

exposes user data Risk level: High

Business impact: Data scraping may reduce service performance and expose

business data patterns. Remediation suggestion: Require API keys or

authentication tokens for data access.

Finding 2 - Cross-region Isolation Policies

Security & Isolation

Secure Context	Yes
Cross-Origin Isolated	No
Cross-Origin Embedder Policy (COEP)	none
Cross-Origin Opener Policy (COOP)	unsafe-none

Content Security Policy (CSP)

Content-Security-Policy	None
-------------------------	------

Observation: Certain cross-origin isolation policies were not enabled.

Risk Level: Low

Explanation: These policies mainly protect browser-based applications. Since this API functions primarily as a data service, the security impact is limited.

Remediation suggestions: Consider enabling stricter cross-origin policies if the API is consumed directly by web applications handling sensitive data.

Finding 3 -High Rate Limit Threshold

x-ratelimit-limit	1000
x-ratelimit-remaining	999
x-ratelimit-reset	1773129132

Observation: Rate limiting is implemented (1000 requests

allowed per time window). Risk Level: Low

Explanation: Rate limiting helps prevent abuse and automated attacks. However, a high threshold may still allow large-scale automated data collection.

Remediation suggestions: Consider adaptive rate limiting based on user behavior and sensitivity of endpoints.

Finding 4 - Visible Reporting Endpoints

report-to	{"group":"heroku-nel","endpoints":[{"url":"https://nel.heroku.com/rep...
reporting-endpoints	heroku-nel="https://nel.heroku.com/reports?s=N36drKUGDuHOcT...

Observation: Reporting-related endpoints

are publicly visible. Risk Level: Low

Explanation: Public visibility of endpoints is common in API design. However, exposing operational endpoints may provide attackers with insight into system structure.

Remediation suggestions: Ensure monitoring and reporting endpoints require authentication and avoid exposing sensitive operational data.

—Thank You—